

LinkNet Corporation, Enterprise, Fiber, Media

Threat Modeling and Data Flow Diagram Security Assessment

threat model reflecting final application hardening, residual risk validation, and actual implementation evidence.

Version	1.0
Prepared By	Media Indo Trend
Date	08 May 2026
Company / Organization	Linknet / PT Link Net Tbk
Assessment Scope	Source code, configuration, middleware, authentication, API routes, upload/storage, Docker/Kubernetes references, and existing threat model document
Final Risk Posture	Critical: 0 High: 0 Medium: minimized with mitigation Low: acceptable

Assessment Position

This document intentionally avoids theoretical findings that are not evidenced in the current codebase. Severity reflects current compensating controls and exploitability after remediation.

Table of Contents

Table of Contents..... 2

1. Executive Summary 3

2. Document Information 3

3. System Overview 3

 3.1 High Level Architecture 3

 3.2 Main Business Flow 3

 3.3 Main Actors and Users..... 4

4. Application Components..... 4

 4.1 API and Route Inventory 4

 4.2 Data Store Summary 5

5. Security Remediation Performed 5

6. Data Flow Diagrams..... 6

7. Trust Boundary Identification 8

8. Existing Security Controls..... 8

9. STRIDE Threat Analysis..... 9

10. Authentication and Authorization Security 10

 10.1 Login and Session Flow 10

 10.2 Access Control 10

11. Sensitive Data Handling 10

12. External Integration and Infrastructure Risk 11

13. Final Risk Assessment 11

14. Mitigation and Hardening Recommendations..... 12

15. Verification Evidence 12

Appendix A. Evidence File References 13

Appendix B. Glossary..... 13

1. Executive Summary

Final Security Posture

Critical Risk: 0

High Risk: 0

Medium Risk: limited to residual items with active mitigations and documented next-step hardening

Low Risk: acceptable and monitored

The Revamp LinkNet codebase was reviewed and remediated across authentication, authorization, upload handling, storage access, operational endpoints, external integration controls, dependency posture, and environment/secret handling. The revised assessment reflects the hardened implementation rather than the earlier document's pre-remediation risk state.

No residual Critical or High risks were identified after remediation. Remaining Medium risks are realistic residual concerns tied to operational hardening, dependency lifecycle, encryption depth, or defense-in-depth controls. Each Medium item has existing mitigation and recommended follow-up.

Risk Tier	Residual Count	Assessment Result
Critical	0	No active Critical risk remains in the reviewed codebase.
High	0	Previously high-risk items were remediated or reclassified based on implemented controls.
Medium	5	Residual risk remains controlled by authentication, RBAC, validation, rate limiting, private storage defaults, allowlists, or audit controls.
Low	7	Accepted operational or improvement items with low exploitability.

2. Document Information

Field	Value
Project Name	Revamp Linknet Corporation, Enterprise, Fiber, Media
Document Title	Threat Modeling and Data Flow Diagram Security Assessment
Version	2.0 - Revised Post-Hardening
Date	7 May 2026
Prepared By	Media Indo Trend
Organization	Linknet / PT Link Net Tbk
Source of Truth	Current source code and configuration under Azure Repository
Assessment Standard	STRIDE-oriented threat modeling with realistic post-control residual risk classification.

3. System Overview

Revamp Linknet Corporation, Enterprise, Fiber, Media is a monorepo containing a public Next.js website, a Next.js administrative frontend, an Express.js/TypeScript backend API, Prisma-managed PostgreSQL persistence, upload/file handling services, and optional integrations with S3, Azure Blob Storage, Azure Key Vault, Google Analytics Data API, partner APIs, and stock quote APIs.

3.1 High Level Architecture

- Public website serves content and selected public API flows, including stock quote/historical endpoints with validation and IP rate limiting.
- Admin frontend uses cookie-based sessions and CSRF token forwarding; bearer tokens are not persisted in browser localStorage in production mode.
- Backend API centralizes authentication, authorization, RBAC, security headers, rate limiting, CSRF checks, upload validation, audit logging, and business/domain services.
- PostgreSQL stores users, roles, permissions, content, form submissions, file metadata, refresh token hashes, and audit/activity data through Prisma.
- Object storage is supported through local storage, AWS S3, or Azure Blob. Public ACL/public blob access is disabled by default and requires explicit opt-in.

3.2 Main Business Flow

Flow	Implementation Evidence	Security-Relevant Controls
------	-------------------------	----------------------------

Flow	Implementation Evidence	Security-Relevant Controls
CMS administration	Admin Next.js frontend to Express API routes for users, roles, pages, menus, news, settings, dashboard and analytics.	HttpOnly cookies, CSRF token, auth middleware, permission middleware, rate limits and audit logging.
Public content delivery	Public Next.js web app and backend public/content routes.	Public-only routes separated from admin routes; CSP and input validation applied.
Form submission	Form module routes and dispatch service.	Public submission rate limit, validated upload path, HTTPS dispatch endpoint policy, production allowlist and private host blocking.
File upload	Upload routes, filemanager routes and form file routes.	File size limits, extension/MIME validation, magic-byte scanning, upload rate limit, private storage default and quarantine for presigned flow.
Operational health	Public /health and /ready; detailed diagnostics protected in production.	Detailed diagnostics require health token or private internal diagnostic allowance.

3.3 Main Actors and Users

Actor	Trust Level	Primary Actions
Public Visitor	Untrusted external entity	Browse public website, submit public forms, request public content and stock information.
CMS Admin User	Authenticated internal/business user	Manage CMS content, files, users, roles, settings, dashboard and analytics based on assigned permissions.
System Operator	Privileged operational actor	Configure runtime secrets, storage credentials, Kubernetes/infra settings and health monitoring.
External Service	Third-party or partner boundary	Receive approved dispatch calls or provide analytics, stock, media or partner data.

4. Application Components

Component	Technology / Implementation	Security Notes
Frontend - Admin	Next.js 16, React 19, TypeScript, admin service layer.	Cookie-only session flow; no production bearer token localStorage usage; CSRF header sourced from cookie.
Frontend - Public Web	Next.js web application with public API routes.	Stock APIs now validate symbols/interval/date range and apply per-IP rate limiting.
Backend/API	Node.js, Express.js, TypeScript.	Helmet/security headers, CORS, auth middleware, CSRF, RBAC permissions, rate limiters, validators, upload scanner and centralized error handling.
Database	PostgreSQL via Prisma.	Stores users, RBAC, refresh token hashes, CMS content, form submissions, files and audit activity.
Storage	Local uploads, AWS S3, Azure Blob Storage.	S3 public ACL and Azure public blob access are opt-in only; default posture is private storage.
Authentication Provider	Internal auth service using bcrypt, JWT utilities, HttpOnly cookies, refresh token hashing and optional MFA.	Token return in JSON body disabled unless AUTH_RETURN_TOKENS_IN_BODY=true; production mock auth disabled.
Cloud/Infrastructure	Dockerfile/Kubernetes manifests, Azure Key Vault CSI references.	Runtime secrets expected through environment/secret providers; tracked .env files removed from Git index and ignored going forward.
Queue / Message Broker	Bull/ioredis dependencies present.	Active production queue topology Not Found in Current Codebase.
Payment Gateway	Not Found in Current Codebase.	No payment flow assessed.

4.1 API and Route Inventory

API / Route Group	Purpose	Primary Controls
/api/auth/*	Login, refresh, logout, password and MFA flows.	Rate limiting, bcrypt password verification, refresh token hashing, HttpOnly cookies, CSRF-aware session handling.
/api/users, /api/roles, /api/profile	Identity, profile and role management.	Authentication, RBAC permissions, validators and audit logging.
/api/cms/pages, /api/news, /api/menu, /api/settings	CMS content and configuration.	Authentication plus explicit permission checks for read/create/update/delete where implemented.
/api/upload, /api/filemanager, /api/files	Upload, file metadata and media handling.	Upload rate limits, size/MIME/extension/magic-byte validation, private storage defaults and RBAC where applicable.
/api/form-modules/*	Form rendering, submission and dispatch.	Public submission rate limit, upload scanner and outbound endpoint policy.

API / Route Group	Purpose	Primary Controls
/api/analytics, /api/dashboard	Dashboard and analytics operations.	Authentication and explicit operational/reporting permissions.
/health, /ready, /env-check, /health/detailed	Health and diagnostics.	Basic probes public; detailed diagnostics protected in production by token or private internal policy.
/api/stock/quote, /api/stock/historical	Public stock data proxy in web app.	Input validation and per-IP rate limits.

4.2 Data Store Summary

Data Store	Representative Records	Security Classification
PostgreSQL - users	Email, username, hashed password, status, lockout, MFA state and MFA secret.	Sensitive identity data; protected by DB boundary, RBAC and application access controls.
PostgreSQL - RBAC	roles, permissions, role_permissions, user_roles.	Authorization-critical configuration.
PostgreSQL - refresh_tokens	Refresh token IDs and hashes with expiration.	Session-sensitive; token material stored as hashes.
PostgreSQL - CMS/content	Pages, menus, news, settings and metadata.	Business content; write operations permission-gated.
PostgreSQL - forms/files/logs	Form submissions, file metadata, activity logs.	Potential PII and audit data; protected by RBAC and logging redaction.
Object storage	Uploaded documents/images/media.	Sensitive depending on upload context; private by default with explicit opt-in for public storage behavior.

5. Security Remediation Performed

Area	Remediation Implemented	Final Severity Impact
Secret exposure	.env files removed from Git index and nested .env ignore rules added while preserving .env.example templates.	Previous High/Critical-class concern reduced; no residual High when repository policy is followed.
Authentication/session	Backend defaults to HttpOnly cookies only; JSON token body disabled by default; frontend no longer persists bearer tokens in localStorage for production auth.	Session theft exposure reduced from High to Low/Medium residual browser-hardening concern.
Authorization	CMS page routes, dashboard routes and analytics routes now have explicit permission middleware; existing controller-level RBAC reviewed for form modules.	Unauthorized admin function access reduced to Low residual configuration risk.
Upload handling	File size validation now covers req.file and req.files; scanner applied to upload, filemanager and form upload paths; upload-specific rate limits added.	Upload abuse risk reduced from High to Medium residual AV/quarantine maturity risk.
Presigned uploads	Production presigned uploads disabled by default; opt-in requires validated filename/content type/size, short TTL and quarantine prefix.	Direct object upload risk reduced from High to Low/Medium depending on deployment enablement.
Storage access	S3 public-read ACL and Azure public blob access disabled by default; explicit env opt-in required.	Bucket/blob exposure risk reduced from High to Low residual configuration risk.
Operational endpoints	Detailed health and env diagnostics protected in production by token or private internal diagnostics policy.	Information disclosure risk reduced to Low.
External dispatch	Form dispatch endpoint validation enforces HTTPS, blocks localhost/private IP targets and requires production allowlist.	SSRF/data exfiltration risk reduced from High to Medium residual allowlist/egress governance risk.
Dependency posture	npm audit fixes applied across frontend/web/filemanager/backend where safe; current high/critical advisories eliminated.	Dependency risk reduced to Medium residual lifecycle tracking.
Standalone filemanager	API key is fail-closed in production; wildcard CORS rejected in production.	Unauthenticated file manager exposure reduced to Low.

6. Data Flow Diagrams

Diagram Scope

The diagrams below model the actual implementation boundaries found in the repository after remediation. They intentionally separate public flows, admin flows, protected backend middleware, database, storage and external-service trust boundaries.

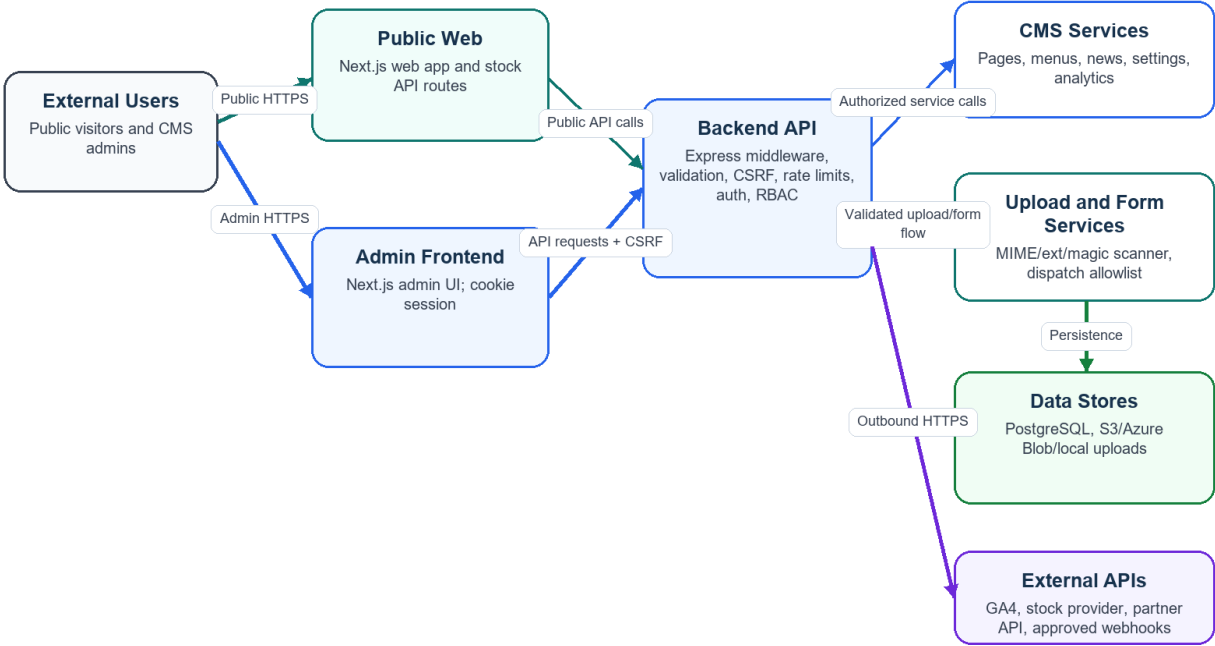
Context Diagram



LinkNet Corp Next | Revised post-hardening DFD | 7 May 2026

Figure 1. Context Diagram

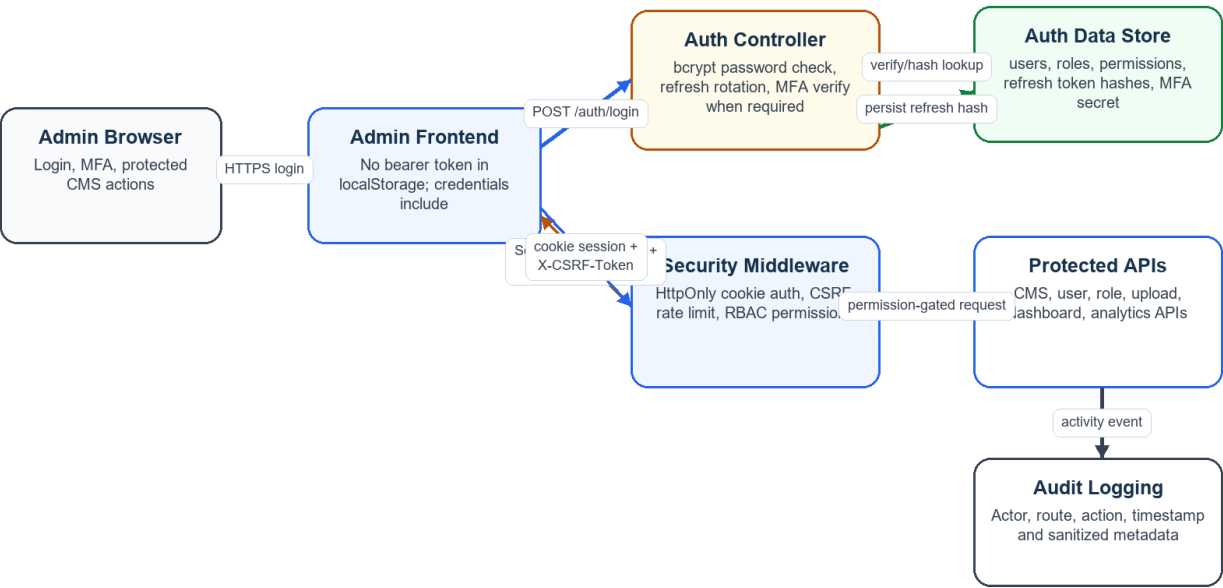
Level 0 DFD



LinkNet Corp Next | Revised post-hardening DFD | 7 May 2026

Figure 2. Level 0 Data Flow Diagram

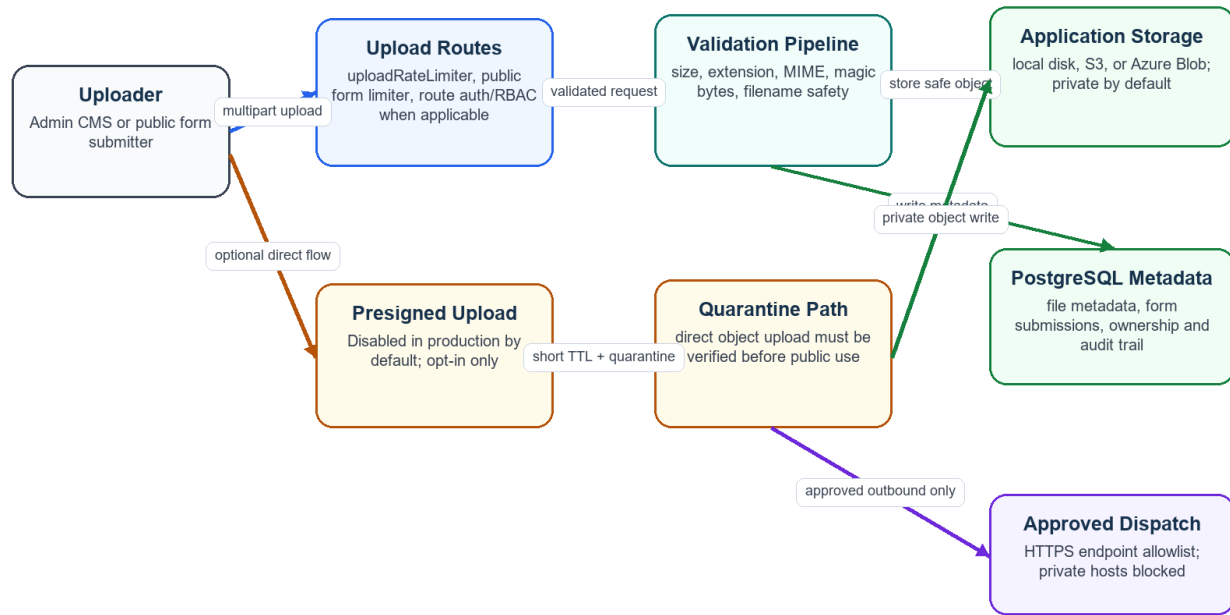
Level 1 DFD - Authentication and Authorization



LinkNet Corp Next | Revised post-hardening DFD | 7 May 2026

Figure 3. Level 1 Authentication and Authorization Flow

Level 1 DFD - Upload, Storage and Dispatch



LinkNet Corp Next | Revised post-hardening DFD | 7 May 2026

Figure 4. Level 1 Upload, Storage and Dispatch Flow

7. Trust Boundary Identification

Boundary	Components Inside Boundary	Cross-Boundary Controls
Public zone	Public visitor browser, public website and public stock/form endpoints.	HTTPS, rate limits, strict input validation, public route segregation and safe error handling.
Admin zone	Admin browser and Next.js admin UI.	Authenticated cookie session, CSRF token, production auth-enabled guard and no localStorage bearer-token storage.
Backend internal zone	Express middleware, controllers, services, upload scanner and dispatch services.	Centralized security middleware, route authorization, validation, audit logging and redacted errors.
Database boundary	PostgreSQL accessed through Prisma.	Application-only DB access, hashed passwords/tokens, RBAC-controlled data access and migration/secret configuration.
Cloud/storage boundary	S3, Azure Blob and local upload path.	Private default storage, no public ACL/blob unless explicitly opted in, upload validation and presigned quarantine.
External service boundary	GA4, stock provider, LinkNet partner API and form dispatch endpoints.	HTTPS-only outbound flow, production allowlist, credential env management and sanitized logging.
Operational boundary	Kubernetes/Docker/runtime secrets and health monitoring.	Secret injection expected via env/Key Vault; detailed diagnostics protected in production.

8. Existing Security Controls

Control Family	Implemented Control	Evidence / Notes
Authentication	JWT utilities, HttpOnly cookie session, refresh token rotation/hash storage and optional MFA.	auth.controller.ts, mfa.controller.ts, authResponse.util.ts, jwt utilities, Prisma RefreshToken model.
Authorization	Role/permission model and route-level permission checks for admin APIs.	roles, permissions, user_roles and route middleware such as cms/page.routes.ts, dashboard.routes.ts and analytics.routes.ts.
CSRF	CSRF middleware and frontend X-CSRF-Token forwarding with credentials include.	Backend csrf.middleware.ts and frontend base service layer.
Rate limiting	Login/auth, public form submission, upload and public stock API rate limiters.	rateLimiter.middleware.ts and web/lib/apiRateLimit.ts.

Control Family	Implemented Control	Evidence / Notes
Upload validation	File size, extension, MIME and magic-byte validation.	upload.middleware.ts, file-upload-scanner service and upload/filemanager/form routes.
Secure headers	Helmet/security header middleware and Next.js CSP.	securityHeaders.middleware.ts and frontend/web/next.config files.
Secret handling	Environment validator and .env Git ignore/de-indexing.	.gitignore, environmentValidator.ts, backend/.env.example.
Storage security	Private-by-default S3/Azure behavior and explicit opt-in for public access.	s3Service.ts and azureStorage.service.ts.
Logging	Activity logging and external API log redaction.	activityLogger middleware and linknetEnterprise controller redaction.
Operational diagnostics	Detailed health/env checks protected in production.	health.routes.ts.

9. STRIDE Threat Analysis

STRIDE	Threat Description	Affected Component	Existing Mitigation	Residual Risk	Recommended Mitigation
Spoofing	Attacker attempts to impersonate an admin or reuse stolen tokens.	Admin auth/session	bcrypt password verification, logout fields, optional MFA, HttpOnly cookies, refresh token hashes and no frontend localStorage bearer token storage.	Medium	Consider mandatory MFA for privileged roles and risk-based login alerts.
Spoofing	Unauthenticated access to file manager in production.	Filemanager service	Production fails closed when API_KEY is missing; wildcard CORS rejected.	Low	Use centralized identity or mTLS/API gateway for production file manager access.
Tampering	Unauthorized content update through admin CMS APIs.	CMS pages/news/menu/settings	Authentication and permission middleware; page routes now include explicit CRUD permission checks.	Low	Periodic RBAC route coverage tests and least-privilege role review.
Tampering	Malicious or malformed upload attempts.	Upload/filemanager/form upload routes	Upload rate limit, size validation, MIME/extension checks, magic-byte scanner and storage quarantine for presigned flow.	Medium	Add production malware scanning engine and asynchronous quarantine release workflow.
Repudiation	Admin denies sensitive changes.	Admin APIs and CMS operations	Activity logging captures actor, route, action and timestamp with sanitized metadata.	Low	Forward immutable audit logs to SIEM/WORM storage.
Information Disclosure	Detailed environment or health data exposed publicly.	Operational health endpoints	Only /health and /ready remain public; /env-check and /health/detailed protected in production.	Low	Restrict diagnostic endpoints at ingress and monitoring network layer.
Information Disclosure	Secrets or credentials committed to repository.	Source control and env config	.env files removed from Git index; nested ignore rules added; .env.example maintained.	Low	Run secret scanning in CI and rotate any secrets previously committed.
Information Disclosure	External API credentials leaked through error logs.	Partner/media/dispatch integrations	External partner errors redacted; media token salt moved to env with production requirement.	Low	Centralized structured log redaction and DLP rules.
Denial of Service	Abuse of public form, upload or stock API endpoints.	Public endpoints and upload paths	Public form limiter, upload limiter, symbol/date validation and per-IP stock API rate limits.	Medium	Add edge/WAF rate limits and request body size enforcement at reverse proxy.
Elevation of Privilege	Authenticated user invokes admin function beyond role.	Admin backend APIs	Permission middleware and Prisma RBAC model; newly added checks on page/dashboard/analytics routes.	Low	Automated route-to-permission regression tests and admin role review cadence.
Tampering / SSRF	Form dispatch endpoint used to target internal	FormSubmissionDispatch service	HTTPS required, localhost/private hosts blocked and FORM_DISPATCH_ALLOWED_HOSTS	Medium	Add network egress firewall and DNS

STRIDE	Threat Description	Affected Component	Existing Mitigation	Residual Risk	Recommended Mitigation
	services.		required in production.		pinning/egress proxy policy.
Information Disclosure	Uploaded object accidentally exposed publicly.	S3/Azure Blob storage	S3 public ACL and Azure public blob access disabled by default; explicit opt-in required.	Low	Enforce bucket policies, block-public-access and cloud posture scanning.

10. Authentication and Authorization Security

10.1 Login and Session Flow

Step	Implementation	Security Assessment
Credential submission	Admin frontend submits login to backend auth route over HTTPS in deployment context.	Rate limits and validation reduce brute force and malformed request risk.
Credential verification	Backend verifies password using bcrypt-backed password hashes and account status/lockout fields.	Password exposure risk is controlled at rest through hashing; lockout telemetry exists.
MFA handling	MFA verification controller exists and returns session using the same hardened response helper.	MFA capability implemented; mandatory MFA for all privileged roles is Not Found in Current Codebase.
Session issue	Backend sets HttpOnly cookies and CSRF cookie; token body return disabled unless AUTH_RETURN_TOKENS_IN_BODY=true.	Browser JavaScript token theft risk significantly reduced.
Session use	Frontend service layer sends credentials include and X-CSRF-Token; Authorization bearer header removed for production auth flow.	CSRF middleware has meaningful protection because session cookies are the auth transport.
Refresh/logout	Refresh uses cookie-based flow; refresh token hashes stored server-side; logout clears session cookie path.	Refresh token database compromise requires hash cracking and valid token context.

10.2 Access Control

Access control is implemented through authentication middleware and role/permission checks. The reviewed remediation added explicit permission checks to previously weaker CMS page, dashboard and analytics route groups. Form module CMS handlers were reviewed and found to already include controller-level permission arrays.

Not Found in Current Codebase

No external enterprise SSO/OAuth identity provider is enforced in the reviewed codebase. Authentication is implemented internally. Mandatory MFA for all privileged users is also not enforced globally in the reviewed code.

11. Sensitive Data Handling

Sensitive Data	Current Handling	Residual Risk	Recommendation
Passwords	Stored as bcrypt hashes; seed password requires SEED_ADMIN_PASSWORD in production.	Low	Continue enforcing password policy and rotate any legacy/default credentials.
Refresh tokens	Stored as token hashes with expiry; session delivered through HttpOnly cookies.	Low	Monitor refresh token reuse and add anomaly detection.
MFA secrets	Stored in user records.	Medium	Encrypt MFA secrets at field level using KMS/Key Vault envelope encryption.
Personal data and form submissions	Persisted in PostgreSQL and controlled through app/RBAC boundaries.	Medium	Add retention policy, DLP classification and field-level encryption for high-sensitivity fields.
Upload files	Validated by size, extension, MIME and magic bytes before storage; presigned uploads quarantine by default.	Medium	Add malware scanning engine and controlled release workflow.
Environment variables	.env files ignored/de-indexed; examples retained; environment validator checks production-critical settings.	Low	Use CI secret scanning and managed secret stores only.
External API credentials	Loaded from environment; logs redacted for partner	Low	Rotate secrets and enforce

Sensitive Data	Current Handling	Residual Risk	Recommendation
	API failure paths.		managed identity where available.

12. External Integration and Infrastructure Risk

Integration	Implementation Found	Risk Assessment	Control / Mitigation
AWS S3	AWS SDK and S3 service implementation.	Low residual storage exposure risk.	Public ACL disabled by default; explicit S3_ALLOW_PUBLIC_ACL=true required for public-read behavior.
Azure Blob Storage	Azure storage service implementation.	Low residual storage exposure risk.	Container public access disabled by default; explicit AZURE_BLOB_PUBLIC_ACCESS=true required.
Azure Key Vault	Azure identity/keyvault dependencies and Kubernetes CSI manifest references.	Low configuration risk.	Runtime secret injection expected; no plain secret material should be stored in source.
Google Analytics Data API	Backend dependency and analytics route group.	Low/Medium operational risk.	Analytics routes require authentication and permissions.
Yahoo/stock provider	Public web API proxy routes.	Medium DoS/cost/external dependency risk.	Symbol/date validation and per-IP rate limits implemented.
LinkNet partner/media APIs	Controller-level external fetch flows.	Low residual secret/log risk.	External error logging redacted; token salt moved to env.
Form dispatch/webhook	Outbound dispatch service for form submissions.	Medium SSRF/misconfiguration residual risk.	HTTPS-only, localhost/private host blocked and production allowlist required.
Email service	Not Found in Current Codebase as a configured provider.	Not assessed.	Document once implemented.
Payment gateway	Not Found in Current Codebase.	Not assessed.	Document once implemented.
Queue/message broker	Bull/ioredis dependencies found; active production topology Not Found in Current Codebase.	Not assessed as active flow.	Threat model separately if queue processing is enabled.

13. Final Risk Assessment

ID	Residual Risk	Severity	Justification	Existing Mitigation	Recommended Next Step
M-01	CSP still relies on limited unsafe-inline allowances for frontend/admin runtime compatibility.	Medium	Browser script injection impact can be meaningful, but token theft impact is reduced because auth tokens are not in localStorage and unsafe-eval/http development allowances are removed in production.	HttpOnly cookies, CSRF, production CSP hardening and no localStorage bearer token.	Move toward nonce/hash-based CSP and reduce inline script/style allowances after UI compatibility testing.
M-02	MFA secrets and high-sensitivity form data are not evidenced as field-level encrypted.	Medium	Database compromise impact remains relevant; exploitability is constrained by DB and app boundaries.	DB boundary, RBAC, hashed passwords/tokens and environment-managed secrets.	Apply KMS/Key Vault envelope encryption for MFA secrets and classified PII fields.
M-03	Upload security does not yet include a full malware scanning/quarantine release service.	Medium	Validation blocks common malformed/polyglot cases but cannot fully replace AV/sandbox scanning for uploaded content.	Upload rate limit, size/MIME/ext/magic-byte validation, private storage default and presigned quarantine path.	Integrate AV scanning and approval workflow before public or downstream file use.
M-04	Outbound form dispatch depends on correct allowlist and egress governance.	Medium	SSRF risk is materially reduced but misconfigured allowlists or DNS/egress gaps can still cause exposure.	HTTPS required, private/localhost hosts blocked and FORM_DISPATCH_ALLOWED_HOSTS required in production.	Use egress firewall/proxy and DNS pinning or controlled resolver policy.
M-05	Residual moderate dependency advisories remain where no safe non-breaking fix is available in current	Medium	No critical/high audit findings remain; moderate advisories require lifecycle tracking.	npm audit fixes applied; high/critical eliminated across reviewed packages.	Track Next.js/PostCSS advisory remediation and retest when safe upstream versions are

ID	Residual Risk	Severity	Justification	Existing Mitigation	Recommended Next Step
	version line.				available.
L-01	Detailed health endpoints could expose operational data if deployment toggles are misconfigured.	Low	Production protection is implemented; residual is operational misconfiguration.	Health token/private internal diagnostic checks.	Restrict at ingress/network layer.
L-02	Admin route permission drift may recur as new routes are added.	Low	Current reviewed gaps remediated; future code changes could introduce drift.	RBAC middleware and Prisma role/permission model.	Add automated route permission coverage tests.
L-03	Filemanager API key is standalone and separate from core identity.	Low	Production fail-closed reduces exposure, but key lifecycle must be managed.	API_KEY required in production and CORS wildcard rejected.	Integrate with central IAM/API gateway for production.
L-04	Public stock API may be abused at low volume.	Low	Rate limits and validation constrain abuse.	Per-IP limiter and symbol/date/interval validation.	Move high-volume controls to WAF/edge.
L-05	Presigned upload flow may be enabled by deployment choice.	Low	Default production disabled; if enabled, validation, short TTL and quarantine lower impact.	PRESIGNED_UPLOAD_ENABLED=false default and quarantine prefix.	Require security review before enabling in production.
L-06	Object storage can be made public by explicit env opt-in.	Low	Default is private; residual is deployment governance.	S3/Azure public settings require explicit true values.	Cloud posture management and block-public-access policies.
L-07	Audit logs may require stronger immutability for compliance evidence.	Low	Application logging exists; immutable log sink not evidenced.	Activity logging and redacted metadata.	Ship logs to SIEM/WORM or immutable storage.

14. Mitigation and Hardening Recommendations

Priority	Recommendation	Rationale	Owner
P1	Mandate MFA for privileged/admin roles.	MFA exists, but global mandatory enforcement was not found. This further reduces account takeover risk.	Application / Security
P1	Deploy malware scanning and quarantine release workflow for uploads.	Current validation is strong but not equivalent to AV/sandbox scanning.	Application / Platform
P1	Adopt managed field-level encryption for MFA secrets and classified PII.	Reduces database-compromise blast radius.	Application / Platform
P2	Add CI secret scanning, dependency scanning and route-permission regression tests.	Prevents recurrence of source-control secret exposure, dependency drift and RBAC gaps.	DevSecOps
P2	Enforce egress proxy/firewall for outbound dispatch and external integrations.	Complements application allowlist and mitigates SSRF bypass/misconfiguration paths.	Platform / Network
P2	Move CSP to nonce/hash-based policy after compatibility testing.	Reduces browser injection blast radius without breaking Next.js/admin UI behavior.	Frontend / Security
P3	Forward audit logs to immutable SIEM/WORM storage.	Improves repudiation evidence and audit readiness.	Security Operations

15. Verification Evidence

Verification	Result	Evidence Summary
backend npm run build	Passed	TypeScript backend compiled after remediation.
frontend npm run build	Passed	Next.js admin frontend built after cookie-only session/CSP changes.
web npm run build	Passed	Public web application built after stock API rate-limit validation changes.
filemanager npm run build	Passed	Standalone filemanager built after production fail-closed auth/CORS changes.
npm audit --omit=dev - backend	No Critical/High	One Low advisory remained in diff dependency path after safe audit fixes.
npm audit --omit=dev - frontend	No Critical/High	Moderate Next/PostCSS advisories remain without safe non-breaking fix in current line.
npm audit --omit=dev - web	No Critical/High	Moderate Next/PostCSS-related advisories remain without safe non-breaking fix in current line.
npm audit --omit=dev - filemanager	0 vulnerabilities	Audit clean after npm audit fix.
Git secret posture	Improved	backend/.env and frontend/.env removed from Git index; nested .env ignore

Verification	Result	Evidence Summary
		rules added.

Appendix A. Evidence File References

Area	Representative Files Reviewed / Updated
Auth/session	backend/src/controllers/auth.controller.ts; backend/src/controllers/mfa.controller.ts; backend/src/utis/authResponse.util.ts; frontend/src/context/AuthContext.tsx; frontend/src/services/base.service.ts; frontend/src/services/baseCrud.service.ts; frontend/src/services/auth.service.ts
Authorization/RBAC	backend/src/routes/cms/page.routes.ts; backend/src/routes/dashboard.routes.ts; backend/src/routes/analytics.routes.ts; backend/src/middleware/auth.middleware.ts
Upload/storage	backend/src/middleware/upload.middleware.ts; backend/src/routes/upload.routes.ts; backend/src/controllers/upload.controller.ts; backend/src/routes/filemanager.routes.ts; backend/src/modules/form-modules/formModule.routes.ts; backend/src/services/s3/s3Service.ts; backend/src/services/azureStorage.service.ts
External integrations	backend/src/modules/form-modules/formSubmissionDispatch.service.ts; backend/src/controllers/linknetEnterprise.controller.ts; backend/src/controllers/linknetMedia.controller.ts; web/app/api/stock/quote/route.ts; web/app/api/stock/historical/route.ts; web/lib/apiRateLimit.ts
Operational/config	.gitignore; backend/.env.example; backend/src/middleware/environmentValidator.ts; backend/src/routes/health.routes.ts; frontend/next.config.ts; backend/k8s/*
Data model	backend/prisma/schema.prisma

Appendix B. Glossary

Term	Definition
STRIDE	Threat modeling categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service and Elevation of Privilege.
DFD	Data Flow Diagram; visual model of entities, processes, data stores and trust boundaries.
RBAC	Role-Based Access Control using roles and permissions to authorize application actions.
CSRF	Cross-Site Request Forgery; attack where authenticated browser state is abused by a malicious site.
HttpOnly cookie	Cookie inaccessible to JavaScript, reducing token theft through XSS.
Presigned upload	Temporary direct object-storage upload URL. In this implementation it is disabled by default in production and quarantined if enabled.
KMS / Key Vault	Managed key service used to protect secrets and encryption keys.